

Preguntas de Verdadero/Falso – Hacking Ético y Malware (200)

BLOQUE 1 – Preguntas 1 a 50

1. El hacking ético siempre debe realizarse con autorización formal por escrito.
Verdadero/Falso: Verdadero
Explicación: Se requiere autorización para cumplir con estándares éticos y legales.
Referencia: [ISO/IEC 27001](#)
2. Una auditoría de seguridad solo busca cumplir con ISO/IEC 27001 y no debe reproducir ataques.
Verdadero/Falso: Falso
Explicación: Las auditorías pueden incluir pruebas de penetración simulando ataques reales.
Referencia: [ISO/IEC 27001](#)
3. El reconocimiento (Footprinting) es una fase de pruebas de penetración.
Verdadero/Falso: Verdadero
Explicación: Footprinting recopila información inicial sin interactuar directamente con el objetivo.
Referencia: [NIST SP 800-115](#)
4. El escaneo activo no forma parte de las técnicas de pruebas de penetración reconocidas por NIST.
Verdadero/Falso: Falso
Explicación: El escaneo activo es una etapa documentada para descubrir puertos y servicios.
Referencia: [NIST SP 800-115](#)
5. Los estándares de ciberseguridad buscan reducir riesgos y proteger activos digitales.
Verdadero/Falso: Verdadero
Explicación: Los estándares se diseñan para mitigar riesgos en redes, dispositivos y datos.
Referencia: [ISO/IEC 27001](#)
6. El OWASP Top 10 es un estándar internacional para clasificación de vulnerabilidades web.
Verdadero/Falso: Verdadero
Explicación: OWASP Top 10 categoriza las vulnerabilidades más críticas en aplicaciones web.
Referencia: [OWASP Top 10](#)

7. Una prueba de penetración de caja negra implica conocimiento detallado de la infraestructura antes de la prueba.
Verdadero/Falso: Falso
Explicación: Caja negra simula un ataque sin información previa del objetivo.
Referencia: [Definición caja negra](#)
8. El estándar ISO/IEC 27008 provee guía para auditar controles de seguridad bajo ISO/IEC 27001.
Verdadero/Falso: Verdadero
Explicación: Proporciona orientación sobre auditorías de controles de seguridad.
Referencia: [ISO/IEC 27008](#)
9. Un pentest puede alinearse con ISO/IEC 27001 para apoyar cumplimiento regulatorio.
Verdadero/Falso: Verdadero
Explicación: Las pruebas de penetración ayudan a demostrar cumplimiento del SGSI.
Referencia: [ISO/IEC 27001](#)
10. El NIST SP 800-115 no cubre procedimientos de pruebas de intrusión técnica.
Verdadero/Falso: Falso
Explicación: Incluye guías para pruebas de seguridad, incluyendo intrusión y pentesting.
Referencia: [NIST SP 800-115](#)
11. La recopilación pasiva de información implica interactuar directamente con el objetivo.
Verdadero/Falso: Falso
Explicación: La recopilación pasiva evita interacción directa para no dejar rastros.
Referencia: [NIST SP 800-115](#)
12. La escalada de privilegios es una fase presente en la mayoría de metodologías de pruebas de penetración.
Verdadero/Falso: Verdadero
Explicación: Permite al tester evaluar si puede obtener más control tras la explotación inicial.
Referencia: [NIST SP 800-115](#)
13. Un informe de pruebas de penetración no requiere calibrarse a ninguna norma de reporte internacional.
Verdadero/Falso: Falso
Explicación: Los informes deben seguir buenas prácticas y marcos como ISO 27001 o PTES/OSSTMM.
Referencia: [PTES](#)

14. Meterpreter es una herramienta de explotación usada a menudo en pruebas de penetración.
Verdadero/Falso: Verdadero
Explicación: Forma parte de Metasploit y permite explotación avanzada.
Referencia: [Metasploit](#)
15. Las pruebas de penetración web solo se ocupan de vulnerabilidades fuera del OWASP Top 10.
Verdadero/Falso: Falso
Explicación: Normalmente se priorizan vulnerabilidades del OWASP Top 10 y más.
Referencia: [IBM Pentesting](#)
16. ISO/IEC 27007 guía auditorías de SGSI e incluye cómo evaluar controles técnicos de seguridad.
Verdadero/Falso: Verdadero
Explicación: Proporciona orientación para auditores en la evaluación de controles.
Referencia: [ISO/IEC 27007](#)
17. Una falla de seguridad siempre significa que un atacante tiene acceso completo al sistema.
Verdadero/Falso: Falso
Explicación: Una vulnerabilidad indica riesgo, pero no garantiza acceso completo.
Referencia: [ISO/IEC 27001](#)
18. Metodologías como PTES y OSSTMM se usan en pruebas de penetración profesional.
Verdadero/Falso: Verdadero
Explicación: Son guías metodológicas ampliamente adoptadas en pentesting.
Referencia: [OSSTMM](#)
19. Una prueba de caja gris combina conocimiento parcial del objetivo.
Verdadero/Falso: Verdadero
Explicación: Caja gris proporciona información limitada al tester para pruebas internas y externas.
Referencia: [Pentest tipo caja gris](#)
20. ISO/IEC 27001 solo se aplica a redes y no cubre aplicaciones o datos.
Verdadero/Falso: Falso
Explicación: ISO/IEC 27001 cubre sistemas, datos y aplicaciones dentro de un SGSI.
Referencia: [ISO/IEC 27001](#)
21. Footprinting pasivo permite recopilar información de un objetivo sin ser detectado.
Verdadero/Falso: Verdadero

Explicación: Se basa en fuentes abiertas como DNS, WHOIS o motores de búsqueda.

Referencia: OWASP Footprinting

22. El escaneo de puertos puede realizarse tanto de manera activa como pasiva.

Verdadero/Falso: Verdadero

Explicación: Activo envía paquetes, pasivo monitorea tráfico existente.

Referencia: [NIST SP 800-115](#)

23. ARP Spoofing solo afecta sistemas basados en Linux.

Verdadero/Falso: Falso

Explicación: ARP Spoofing afecta a cualquier sistema en la red local que use ARP.

Referencia: OWASP ARP Spoofing

24. Python puede usarse para automatizar pruebas de penetración y explotación de vulnerabilidades.

Verdadero/Falso: Verdadero

Explicación: Python es ampliamente usado para scripts de explotación y pentesting.

Referencia: Python Security

25. Meterpreter permite obtener acceso persistente en sistemas vulnerables.

Verdadero/Falso: Verdadero

Explicación: Facilita la post-explotación, incluyendo persistencia y control remoto.

Referencia: [Metasploit](#)

26. Una prueba de penetración no requiere registro de evidencias si se hace de forma ética.

Verdadero/Falso: Falso

Explicación: Registrar evidencia es clave para reportes y auditorías posteriores.

Referencia: [PTES Guidelines](#)

27. Los informes de pentesting deben incluir vulnerabilidades y riesgos asociados.

Verdadero/Falso: Verdadero

Explicación: Esto permite priorizar acciones correctivas y cumplir normas ISO/NIST.

Referencia: [ISO/IEC 27001](#)

28. La fase de explotación siempre garantiza acceso total al sistema.

Verdadero/Falso: Falso

Explicación: La explotación depende de la vulnerabilidad y las defensas existentes.

Referencia: [OWASP Testing Guide](#)

29. La ingeniería inversa se utiliza para analizar malware y aplicaciones sospechosas.

Verdadero/Falso: Verdadero

Explicación: Permite entender el comportamiento y riesgos de código malicioso.

Referencia: ISO/IEC 27035

30. El análisis de memoria permite descubrir procesos maliciosos activos en un sistema.

Verdadero/Falso: Verdadero

Explicación: Se examina RAM para detectar malware en ejecución.

Referencia: SANS Memory Forensics

31. La post-explotación nunca incluye captura de credenciales o datos sensibles.

Verdadero/Falso: Falso

Explicación: Post-explotación puede incluir extracción de credenciales, captura de datos y movimiento lateral.

Referencia: [Metasploit Post-Exploitation](#)

32. Las pruebas móviles de seguridad solo aplican a Android.

Verdadero/Falso: Falso

Explicación: También se realizan en iOS y otros sistemas móviles.

Referencia: [OWASP Mobile Top 10](#)

33. MobSF es una herramienta para análisis estático y dinámico de aplicaciones móviles.

Verdadero/Falso: Verdadero

Explicación: Permite detectar vulnerabilidades y riesgos en aplicaciones Android/iOS.

Referencia: [MobSF](#)

34. El malware solo puede ejecutarse si se descarga de fuentes desconocidas.

Verdadero/Falso: Falso

Explicación: Malware puede llegar incluso de fuentes confiables mediante exploits o vulnerabilidades.

Referencia: NIST Malware Analysis

35. Un rootkit es un tipo de malware que oculta su presencia en un sistema.

Verdadero/Falso: Verdadero

Explicación: Rootkits se integran en el kernel o procesos críticos para evitar detección.

Referencia: NIST Malware

36. El análisis estático de malware requiere ejecutar el código sospechoso.

Verdadero/Falso: Falso

Explicación: El análisis estático examina el código sin ejecutarlo.

Referencia: SANS Malware Analysis

37. La ingeniería inversa solo se aplica a software malicioso.

Verdadero/Falso: Falso

Explicación: También se aplica a software propietario para pruebas de

compatibilidad o seguridad.

Referencia: ISO/IEC 27035

38. Una vulnerabilidad crítica siempre permite control total del sistema.

Verdadero/Falso: Falso

Explicación: Crítica indica riesgo alto, pero la explotación depende de múltiples factores.

Referencia: [NIST CVSS](#)

39. Los scripts de Python pueden usarse para automatizar tareas de reconocimiento y explotación.

Verdadero/Falso: Verdadero

Explicación: Python es útil para escaneo, scripting y pruebas repetitivas.

Referencia: Python Security

40. La fase de post-explotación no forma parte de metodologías PTES u OSSTMM.

Verdadero/Falso: Falso

Explicación: Forma parte del ciclo para obtener evidencias y explorar impactos de la vulnerabilidad.

Referencia: [PTES](#)

41. La recopilación de información activa puede incluir envío de paquetes TCP/UDP para descubrir servicios.

Verdadero/Falso: Verdadero

Explicación: Es una técnica estándar para reconocimiento activo en pentesting.

Referencia: [NIST SP 800-115](#)

42. Las vulnerabilidades móviles solo se encuentran en apps instaladas por el usuario.

Verdadero/Falso: Falso

Explicación: Pueden estar en el sistema operativo o apps preinstaladas.

Referencia: [OWASP Mobile Top 10](#)

43. Escalar privilegios permite al pentester simular un ataque interno más realista.

Verdadero/Falso: Verdadero

Explicación: Evalúa riesgos de un usuario con permisos limitados.

Referencia: [NIST SP 800-115](#)

44. Las pruebas de seguridad ética nunca deben documentar los hallazgos.

Verdadero/Falso: Falso

Explicación: La documentación es crítica para remediación y cumplimiento de normas.

Referencia: [ISO/IEC 27001](#)

45. Una vulnerabilidad en una app móvil puede permitir acceso a datos de usuario.

Verdadero/Falso: Verdadero

Explicación: Vulnerabilidades de almacenamiento o permisos inseguros son riesgos comunes.

Referencia: [OWASP Mobile Top 10](#)

46. Los troyanos son un tipo de malware que se ocultan dentro de software legítimo.
Verdadero/Falso: Verdadero
Explicación: Se presentan como software útil mientras realizan acciones maliciosas.
Referencia: NIST Malware
47. La metodología de análisis de malware nunca requiere un entorno aislado.
Verdadero/Falso: Falso
Explicación: Se recomienda usar entornos virtuales o sandbox para evitar daños.
Referencia: SANS Malware Analysis
48. Las pruebas de penetración deben siempre ajustarse al alcance definido.
Verdadero/Falso: Verdadero
Explicación: Para evitar daños no autorizados y cumplir con normas éticas.
Referencia: [PTES](#)
49. Un malware solo puede propagarse mediante archivos adjuntos de correo electrónico.
Verdadero/Falso: Falso
Explicación: Puede propagarse por exploits web, redes, dispositivos removibles, etc.
Referencia: NIST Malware
50. La seguridad en aplicaciones móviles incluye analizar permisos, almacenamiento y comunicación de datos.
Verdadero/Falso: Verdadero
Explicación: Estas áreas son críticas para proteger información sensible del usuario.
Referencia: [OWASP Mobile Top 10](#)

BLOQUE 2 – Preguntas 51 a 100

51. La fase de post-explotación puede incluir movimiento lateral dentro de la red.

Verdadero/Falso: Verdadero

Explicación: Permite evaluar el alcance de la vulnerabilidad dentro de la red.

Referencia: [PTES Post-Exploitation](#)

52. Una vulnerabilidad XSS siempre permite ejecutar código en el servidor.

Verdadero/Falso: Falso

Explicación: XSS afecta al cliente (navegador), no directamente al servidor.

Referencia: [OWASP XSS](#)

53. El análisis dinámico de malware implica ejecutar el código en un entorno controlado.

Verdadero/Falso: Verdadero

Explicación: Se observa comportamiento en tiempo real sin afectar sistemas reales.

Referencia: SANS Malware Analysis

54. Los rootkits solo se encuentran en sistemas Windows.

Verdadero/Falso: Falso

Explicación: Pueden encontrarse en Windows, Linux, macOS y sistemas embebidos.

Referencia: NIST Malware

55. Escalar privilegios en Linux puede permitir acceso a archivos root.

Verdadero/Falso: Verdadero

Explicación: Escalación de privilegios eleva permisos limitados a nivel administrativo.

Referencia: [NIST SP 800-115](#)

56. El análisis de memoria solo sirve para detectar malware residente.

Verdadero/Falso: Falso

Explicación: También puede analizar fugas de datos, procesos sospechosos y manipulación de memoria.

Referencia: SANS Memory Forensics

57. Las pruebas de caja blanca requieren acceso total al código fuente.

Verdadero/Falso: Verdadero

Explicación: Permite revisar todos los componentes del sistema para evaluar seguridad.

Referencia: [OWASP Testing Guide](#)

58. Una prueba de caja negra simula un ataque externo sin conocimiento previo.

Verdadero/Falso: Verdadero

Explicación: Evalúa la resistencia del sistema desde la perspectiva de un atacante externo.

Referencia: [PTES](#)

59. Los certificados SSL/TLS eliminan la necesidad de pruebas de seguridad en aplicaciones web.
Verdadero/Falso: Falso
Explicación: SSL/TLS protege transporte de datos, pero no corrige vulnerabilidades de la aplicación.
Referencia: [OWASP HTTPS Security](#)
60. Las vulnerabilidades en Android e iOS se pueden clasificar siguiendo OWASP Mobile Top 10.
Verdadero/Falso: Verdadero
Explicación: Proporciona marco para identificar riesgos críticos en aplicaciones móviles.
Referencia: [OWASP Mobile Top 10](#)
61. MobSF permite análisis estático de aplicaciones Android e iOS.
Verdadero/Falso: Verdadero
Explicación: Detecta vulnerabilidades de código, configuración y permisos.
Referencia: [MobSF](#)
62. El malware solo se puede analizar dinámicamente en Windows.
Verdadero/Falso: Falso
Explicación: También se pueden analizar en Linux y sistemas móviles usando entornos virtualizados.
Referencia: SANS Malware Analysis
63. La ingeniería inversa es útil para comprender aplicaciones maliciosas o desconocidas.
Verdadero/Falso: Verdadero
Explicación: Ayuda a detectar comportamiento, riesgos y vectores de ataque.
Referencia: ISO/IEC 27035
64. La explotación de vulnerabilidades siempre debe evitarse en un entorno de pruebas controlado.
Verdadero/Falso: Falso
Explicación: Debe realizarse en entornos aislados para evaluar riesgo sin comprometer sistemas reales.
Referencia: [PTES](#)
65. El escaneo de puertos pasivo no genera tráfico detectable en la red objetivo.
Verdadero/Falso: Verdadero
Explicación: Monitorea tráfico existente sin enviar paquetes.
Referencia: [NIST SP 800-115](#)
66. La documentación de hallazgos en pruebas éticas no es necesaria si no se informa al cliente.
Verdadero/Falso: Falso
Explicación: Siempre es necesaria para trazabilidad, remediación y

cumplimiento de normas.

Referencia: [ISO/IEC 27001](#)

67. Meterpreter permite ejecutar comandos en sistemas comprometidos de forma interactiva.

Verdadero/Falso: Verdadero

Explicación: Facilita la post-explotación y pruebas avanzadas de pentesting.

Referencia: [Metasploit](#)

68. Las pruebas de penetración interna simulan ataques desde dentro de la red corporativa.

Verdadero/Falso: Verdadero

Explicación: Evalúa riesgos de un usuario legítimo o atacante que logra acceso interno.

Referencia: [PTES](#)

69. La escalada de privilegios nunca se realiza en sistemas Windows.

Verdadero/Falso: Falso

Explicación: También puede explotarse vulnerabilidades en Windows para elevar permisos.

Referencia: [NIST SP 800-115](#)

70. El análisis de código malicioso puede realizarse de manera estática o dinámica.

Verdadero/Falso: Verdadero

Explicación: Ambas técnicas permiten comprender el malware y su impacto.

Referencia: SANS Malware Analysis

71. Los troyanos se ejecutan automáticamente solo si son abiertos por un usuario.

Verdadero/Falso: Falso

Explicación: Pueden propagarse mediante exploits, macros, redes o dispositivos externos.

Referencia: NIST Malware

72. Una vulnerabilidad en una app móvil puede permitir robo de credenciales.

Verdadero/Falso: Verdadero

Explicación: Mal manejo de permisos o almacenamiento inseguro es un riesgo común.

Referencia: [OWASP Mobile Top 10](#)

73. Las pruebas de penetración nunca deben incluir recolección de datos sensibles como evidencia.

Verdadero/Falso: Falso

Explicación: Se puede recolectar de manera controlada para análisis de riesgos y reporte.

Referencia: [PTES](#)

74. ISO/IEC 27035 cubre gestión de incidentes de seguridad, incluyendo análisis de malware.

Verdadero/Falso: Verdadero

Explicación: Define procedimientos para identificar, reportar y analizar incidentes.

Referencia: ISO/IEC 27035

75. La fase de explotación no debe realizarse nunca durante pruebas de pentesting.

Verdadero/Falso: Falso

Explicación: Es clave para demostrar impacto real de vulnerabilidades.

Referencia: [PTES](#)

76. Las pruebas de caja gris combinan información parcial con técnicas de ataque.

Verdadero/Falso: Verdadero

Explicación: Permite simular ataques internos y externos de manera controlada.

Referencia: [PTES](#)

77. El escaneo activo siempre evita dejar rastros en los sistemas objetivo.

Verdadero/Falso: Falso

Explicación: Envía paquetes que pueden ser detectados por sistemas de defensa.

Referencia: [NIST SP 800-115](#)

78. Los rootkits pueden integrarse al kernel del sistema operativo.

Verdadero/Falso: Verdadero

Explicación: Esto les permite ocultarse y manipular procesos críticos.

Referencia: NIST Malware

79. Python no puede ser usado para explotación de vulnerabilidades.

Verdadero/Falso: Falso

Explicación: Python se usa ampliamente para scripting y automatización de exploits.

Referencia: Python Security

80. La fase de post-explotación evalúa impacto, evidencia y riesgos adicionales.

Verdadero/Falso: Verdadero

Explicación: Permite planificar mitigaciones y entender el alcance de un ataque.

Referencia: [PTES](#)

81. Las pruebas móviles solo deben realizarse en dispositivos físicos.

Verdadero/Falso: Falso

Explicación: También pueden hacerse en emuladores o entornos virtualizados para análisis seguro.

Referencia: [OWASP Mobile Security](#)

82. El malware solo se propaga mediante archivos ejecutables.

Verdadero/Falso: Falso

Explicación: Puede propagarse mediante documentos, scripts, macros, red o dispositivos externos.

Referencia: NIST Malware

83. Escalar privilegios permite realizar pruebas de penetración más completas.
Verdadero/Falso: Verdadero
Explicación: Permite simular ataques internos avanzados y evaluar impacto de vulnerabilidades.
Referencia: [NIST SP 800-115](#)
84. La recopilación pasiva nunca utiliza fuentes públicas como WHOIS o DNS.
Verdadero/Falso: Falso
Explicación: Estas fuentes son esenciales en footprinting pasivo.
Referencia: OWASP Footprinting
85. La documentación de hallazgos ayuda a cumplir normas ISO/IEC 27001.
Verdadero/Falso: Verdadero
Explicación: Permite demostrar auditoría, evidencia y mitigación de riesgos.
Referencia: [ISO/IEC 27001](#)
86. Una vulnerabilidad crítica siempre permite ejecución remota de código.
Verdadero/Falso: Falso
Explicación: Depende del tipo de vulnerabilidad, configuración y defensas.
Referencia: [NIST CVSS](#)
87. La fase de reconocimiento es opcional en pruebas de penetración.
Verdadero/Falso: Falso
Explicación: Es fundamental para recopilar información inicial del objetivo.
Referencia: [PTES](#)
88. Metodologías como OSSTMM cubren técnicas de explotación, post-explotación y reporting.
Verdadero/Falso: Verdadero
Explicación: Proporciona marco integral para pruebas de seguridad profesional.
Referencia: [OSSTMM](#)
89. Una prueba de caja negra siempre requiere acceso a código fuente.
Verdadero/Falso: Falso
Explicación: Caja negra simula un atacante externo sin información interna.
Referencia: [PTES](#)
90. La explotación ética busca demostrar riesgo, no causar daño real.
Verdadero/Falso: Verdadero
Explicación: Es clave para pruebas de penetración seguras y responsables.
Referencia: [PTES](#)
91. Las pruebas de penetración nunca se ajustan al alcance definido por el cliente.
Verdadero/Falso: Falso
Explicación: Ajustarse al alcance evita daños no autorizados y cumple estándares éticos.
Referencia: [ISO/IEC 27001](#)
92. El análisis estático de código puede detectar malware sin ejecutarlo.
Verdadero/Falso: Verdadero

- Explicación: Examina código para identificar comportamientos sospechosos.
Referencia: SANS Malware Analysis
93. Los troyanos se presentan como software legítimo mientras realizan acciones maliciosas.
Verdadero/Falso: Verdadero
Explicación: Se ocultan para engañar al usuario y comprometer sistemas.
Referencia: NIST Malware
94. Las pruebas de penetración solo evalúan sistemas operativos y no aplicaciones.
Verdadero/Falso: Falso
Explicación: También incluyen aplicaciones web, móviles y servicios de red.
Referencia: [OWASP Testing Guide](#)
95. Escanear vulnerabilidades sin autorización es ilegal y no ético.
Verdadero/Falso: Verdadero
Explicación: Solo se permite con autorización formal y alcance definido.
Referencia: [ISO/IEC 27001](#)
96. La fase de explotación no debe documentarse para proteger la confidencialidad del cliente.
Verdadero/Falso: Falso
Explicación: Toda explotación debe documentarse de manera segura para evidencias y remediación.
Referencia: [PTES](#)
97. La recopilación de información activa puede revelar servicios vulnerables.
Verdadero/Falso: Verdadero
Explicación: Escaneo y pruebas activas permiten detectar puertos y servicios abiertos.
Referencia: [NIST SP 800-115](#)
98. ISO/IEC 27035 ayuda a manejar incidentes de seguridad de forma sistemática.
Verdadero/Falso: Verdadero
Explicación: Define procedimientos de identificación, evaluación y mitigación de incidentes.
Referencia: ISO/IEC 27035
99. Los exploits siempre garantizan control total sobre un sistema vulnerable.
Verdadero/Falso: Falso
Explicación: Depende de la vulnerabilidad, contexto y controles de seguridad existentes.
Referencia: [OWASP Exploits](#)
100. Las pruebas de penetración ayudan a mejorar la postura de seguridad de una organización.
Verdadero/Falso: Verdadero
Explicación: Identifican vulnerabilidades, riesgos y ayudan a implementar

medidas correctivas.

Referencia: [ISO/IEC 27001](#)

BLOQUE 3 – Preguntas 101 a 150

101. ARP Spoofing puede permitir a un atacante interceptar tráfico en una red local.

Verdadero/Falso: Verdadero

Explicación: Manipula la tabla ARP para redirigir tráfico hacia el atacante.

Referencia: OWASP ARP Spoofing

102. Las auditorías de seguridad solo se centran en vulnerabilidades técnicas y no consideran procesos.

Verdadero/Falso: Falso

Explicación: También se evalúan políticas, procesos y controles organizacionales.

Referencia: [ISO/IEC 27001](#)

103. El footprinting pasivo nunca revela direcciones IP o nombres de dominio.

Verdadero/Falso: Falso

Explicación: Puede revelar IPs y dominios a través de registros públicos y motores de búsqueda.

Referencia: [NIST SP 800-115](#)

104. La recopilación de información activa puede generar alertas en sistemas de detección de intrusos.

Verdadero/Falso: Verdadero

Explicación: Escanear puertos o enviar paquetes puede ser detectado como actividad sospechosa.

Referencia: [NIST SP 800-115](#)

105. Meterpreter permite interactuar con un sistema comprometido en tiempo real.

Verdadero/Falso: Verdadero

Explicación: Facilita la ejecución de comandos, transferencia de archivos y post-explotación.

Referencia: [Metasploit](#)

106. La escalada de privilegios es irrelevante en pruebas de seguridad si se tiene acceso inicial limitado.

Verdadero/Falso: Falso

Explicación: Es fundamental para evaluar riesgos más allá de un usuario limitado.

Referencia: [NIST SP 800-115](#)

107. Python no puede utilizarse para automatizar ataques de red.

Verdadero/Falso: Falso

Explicación: Python se usa ampliamente para scripting, automatización de exploits y pentesting.

Referencia: Python Security

108. Las pruebas de penetración interna evalúan la seguridad desde dentro de la red corporativa.

Verdadero/Falso: Verdadero

Explicación: Simula el riesgo de un empleado malicioso o intruso interno.

Referencia: [PTES](#)

109. El análisis dinámico de malware permite observar el comportamiento del código en ejecución.

Verdadero/Falso: Verdadero

Explicación: Se ejecuta en sandbox o VM para estudiar efectos sin comprometer sistemas reales.

Referencia: SANS Malware Analysis

110. El malware solo puede propagarse mediante correos electrónicos infectados.

Verdadero/Falso: Falso

Explicación: También se propaga mediante redes, dispositivos USB, exploits y descargas maliciosas.

Referencia: NIST Malware

111. MobSF permite análisis de seguridad tanto estático como dinámico de aplicaciones móviles.

Verdadero/Falso: Verdadero

Explicación: Detecta vulnerabilidades, permisos inseguros y problemas de seguridad en apps.

Referencia: [MobSF](#)

112. El análisis estático de código malicioso requiere ejecutar el código sospechoso.

Verdadero/Falso: Falso

Explicación: Examina código, binarios o scripts sin ejecución para detectar patrones maliciosos.

Referencia: SANS Malware Analysis

113. Las pruebas de caja blanca requieren conocimiento del código fuente del sistema.

Verdadero/Falso: Verdadero

Explicación: Permite revisar la seguridad del código y evaluar todas las rutas posibles de ataque.

Referencia: [OWASP Testing Guide](#)

114. Escanear puertos pasivamente evita generar tráfico detectable en la red.

Verdadero/Falso: Verdadero

Explicación: Se limita a observar tráfico existente en lugar de enviar paquetes.

Referencia: [NIST SP 800-115](#)

115. La documentación de hallazgos es irrelevante si el pentest es solo experimental.

Verdadero/Falso: Falso

Explicación: Documentar hallazgos es clave para auditorías, mitigación y cumplimiento de normas.

Referencia: [ISO/IEC 27001](#)

116. La explotación ética busca demostrar riesgos sin causar daño real a los sistemas.

Verdadero/Falso: Verdadero

Explicación: El objetivo es evidenciar vulnerabilidades de manera segura y controlada.

Referencia: [PTES](#)

117. El malware solo afecta sistemas Windows.

Verdadero/Falso: Falso

Explicación: Puede afectar Linux, macOS, Android, iOS y dispositivos IoT.

Referencia: NIST Malware

118. Escalar privilegios permite evaluar el impacto de vulnerabilidades más allá del usuario inicial.

Verdadero/Falso: Verdadero

Explicación: Fundamental para simular ataques internos y riesgos avanzados.

Referencia: [NIST SP 800-115](#)

119. El análisis de memoria permite identificar malware en ejecución.

Verdadero/Falso: Verdadero

Explicación: Examina procesos activos y puede detectar código malicioso residente.

Referencia: SANS Memory Forensics

120. La fase de post-explotación solo se realiza si el pentester quiere tomar control total del sistema.

Verdadero/Falso: Falso

Explicación: Evalúa impacto, recopila evidencia y ayuda a planificar mitigación de riesgos.

Referencia: [PTES](#)

121. Las pruebas de caja gris combinan conocimiento parcial con ataques controlados.

Verdadero/Falso: Verdadero

Explicación: Simula escenarios realistas donde el atacante tiene información limitada.

Referencia: [PTES](#)

122. ARP Spoofing solo afecta el tráfico de correo electrónico.
Verdadero/Falso: Falso
Explicación: Puede interceptar todo tipo de tráfico en la red local.
Referencia: OWASP ARP Spoofing
123. Una vulnerabilidad crítica indica un riesgo que debe priorizarse para mitigación.
Verdadero/Falso: Verdadero
Explicación: Aunque no siempre garantiza control total, requiere atención inmediata.
Referencia: [NIST CVSS](#)
124. La ingeniería inversa solo se aplica a malware.
Verdadero/Falso: Falso
Explicación: También se aplica a software propietario y aplicaciones desconocidas para análisis de seguridad.
Referencia: ISO/IEC 27035
125. Las pruebas móviles de seguridad incluyen análisis de permisos y almacenamiento de datos.
Verdadero/Falso: Verdadero
Explicación: Evalúa riesgos que puedan comprometer información sensible del usuario.
Referencia: [OWASP Mobile Top 10](#)
126. Rootkits se ocultan integrándose al kernel o procesos críticos del sistema.
Verdadero/Falso: Verdadero
Explicación: Esto dificulta su detección y permite acciones maliciosas continuas.
Referencia: NIST Malware
127. El análisis estático no permite identificar vulnerabilidades en código fuente.
Verdadero/Falso: Falso
Explicación: Permite revisar código y binarios sin ejecutar el programa para detectar problemas.
Referencia: SANS Malware Analysis
128. Una prueba de caja negra no requiere conocimiento previo del objetivo.
Verdadero/Falso: Verdadero
Explicación: Simula ataques externos para evaluar la seguridad desde fuera de la organización.
Referencia: [PTES](#)
129. Escanear vulnerabilidades sin autorización puede ser considerado delito.
Verdadero/Falso: Verdadero

Explicación: Realizar pruebas sin permiso viola leyes y normas éticas.

Referencia: [ISO/IEC 27001](#)

130. Las pruebas de penetración ayudan a cumplir regulaciones y certificaciones internacionales.

Verdadero/Falso: Verdadero

Explicación: Identifican riesgos y permiten implementar controles de seguridad requeridos.

Referencia: [ISO/IEC 27001](#)

131. Una vulnerabilidad siempre garantiza que un atacante obtendrá acceso completo.

Verdadero/Falso: Falso

Explicación: Depende de la configuración, mitigaciones y controles existentes.

Referencia: [NIST CVSS](#)

132. Las pruebas de penetración ética deben seguir alcance y autorización definidos.

Verdadero/Falso: Verdadero

Explicación: Para asegurar legalidad, ética y seguridad durante la evaluación.

Referencia: [PTES](#)

133. Meterpreter puede transferir archivos, ejecutar comandos y mantener persistencia.

Verdadero/Falso: Verdadero

Explicación: Es una herramienta avanzada de post-explotación dentro de Metasploit.

Referencia: [Metasploit](#)

134. Las pruebas de seguridad móvil solo se realizan en dispositivos físicos.

Verdadero/Falso: Falso

Explicación: También pueden realizarse en emuladores y entornos virtuales para análisis seguro.

Referencia: [OWASP Mobile Security](#)

135. La recopilación pasiva nunca utiliza información pública para footprinting.

Verdadero/Falso: Falso

Explicación: WHOIS, DNS y motores de búsqueda son fuentes comunes de footprinting pasivo.

Referencia: OWASP Footprinting

136. Una prueba de penetración puede documentar hallazgos para remediación y auditoría.

Verdadero/Falso: Verdadero

Explicación: La documentación respalda evidencia y permite implementar medidas correctivas.

Referencia: [ISO/IEC 27001](#)

137. La explotación ética busca evidenciar vulnerabilidades sin causar daño real.
Verdadero/Falso: Verdadero
Explicación: Objetivo central de un pentest seguro y responsable.
Referencia: [PTES](#)
138. El malware no puede afectar sistemas Linux ni macOS.
Verdadero/Falso: Falso
Explicación: Linux, macOS y otros sistemas también pueden ser atacados.
Referencia: NIST Malware
139. Escalar privilegios permite evaluar riesgos internos y externos de manera más completa.
Verdadero/Falso: Verdadero
Explicación: Permite simular un atacante con permisos limitados que intenta obtener mayor control.
Referencia: [NIST SP 800-115](#)
140. El análisis de memoria es útil para detectar procesos y malware activos.
Verdadero/Falso: Verdadero
Explicación: Examina RAM y procesos en ejecución para identificar amenazas.
Referencia: SANS Memory Forensics
141. La fase de post-explotación nunca incluye recopilación de evidencia.
Verdadero/Falso: Falso
Explicación: Se recopila evidencia de impacto y vulnerabilidades para reportes.
Referencia: [PTES](#)
142. Las pruebas de caja gris combinan información parcial con técnicas de ataque controladas.
Verdadero/Falso: Verdadero
Explicación: Simula escenarios de ataque más realistas.
Referencia: [PTES](#)
143. ARP Spoofing solo afecta paquetes HTTP.
Verdadero/Falso: Falso
Explicación: Puede interceptar todo tipo de tráfico en la LAN, incluyendo correo, DNS y más.
Referencia: OWASP ARP Spoofing
144. Una vulnerabilidad crítica requiere atención prioritaria, aunque no siempre permite acceso total.
Verdadero/Falso: Verdadero
Explicación: Señala riesgo alto que debe mitigarse rápidamente.
Referencia: [NIST CVSS](#)
145. La ingeniería inversa solo se usa para malware y nunca para software legítimo.
Verdadero/Falso: Falso

Explicación: También se aplica a software propietario para pruebas de seguridad y compatibilidad.

Referencia: ISO/IEC 27035

146. Las pruebas móviles incluyen revisión de almacenamiento de datos y comunicación segura.

Verdadero/Falso: Verdadero

Explicación: Garantiza que datos sensibles estén protegidos contra exfiltración.

Referencia: [OWASP Mobile Top 10](#)

147. Rootkits pueden ocultar procesos y archivos críticos para evitar detección.

Verdadero/Falso: Verdadero

Explicación: Esto permite mantener persistencia y control sobre el sistema.

Referencia: NIST Malware

148. El análisis estático permite revisar código sin ejecutarlo.

Verdadero/Falso: Verdadero

Explicación: Ayuda a detectar vulnerabilidades y patrones maliciosos sin riesgo de ejecución.

Referencia: SANS Malware Analysis

149. Una prueba de caja negra no requiere acceso a información interna de la organización.

Verdadero/Falso: Verdadero

Explicación: Evalúa la seguridad desde el punto de vista de un atacante externo.

Referencia: [PTES](#)

150. Escanear vulnerabilidades sin autorización es ilegal y no ético.

Verdadero/Falso: Verdadero

Explicación: Solo se permite dentro del alcance autorizado de pruebas de seguridad.

Referencia: [ISO/IEC 27001](#)

BLOQUE 4 – Preguntas 151 a 200

151. La fase de reconocimiento es opcional en un pentest.
Verdadero/Falso: Falso
Explicación: Es fundamental para recopilar información inicial del objetivo.
Referencia: [PTES Reconnaissance](#)
152. Footprinting pasivo se realiza sin interactuar directamente con el sistema objetivo.
Verdadero/Falso: Verdadero
Explicación: Se usan fuentes públicas como DNS, WHOIS y motores de búsqueda.
Referencia: OWASP Footprinting
153. Footprinting activo puede ser detectado por sistemas de defensa.
Verdadero/Falso: Verdadero
Explicación: Involucra enviar paquetes que pueden generar alertas en firewalls o IDS.
Referencia: [NIST SP 800-115](#)
154. La recopilación de información no incluye análisis de redes sociales.
Verdadero/Falso: Falso
Explicación: Redes sociales son fuentes útiles de información pública para pentesting.
Referencia: OSINT Guide
155. Crear un mapa de información ayuda a visualizar activos y relaciones dentro de la red.
Verdadero/Falso: Verdadero
Explicación: Facilita planificación de ataques y análisis de riesgos.
Referencia: [PTES](#)
156. Escanear vulnerabilidades solo se realiza una vez durante un pentest.
Verdadero/Falso: Falso
Explicación: Puede repetirse tras remediación o cambios en la red.
Referencia: [NIST SP 800-115](#)
157. Metasploit proporciona interfaces para explotación y post-explotación.
Verdadero/Falso: Verdadero
Explicación: Permite ejecutar exploits, scripts y herramientas como Meterpreter.
Referencia: [Metasploit](#)
158. Meterpreter no permite transferir archivos a sistemas comprometidos.
Verdadero/Falso: Falso
Explicación: Facilita carga/descarga de archivos, ejecución de comandos y persistencia.
Referencia: [Metasploit Meterpreter](#)

159. La escalada de privilegios permite simular ataques más completos.
Verdadero/Falso: Verdadero
Explicación: Eleva permisos de usuario para evaluar riesgos internos avanzados.
Referencia: [NIST SP 800-115](#)
160. La post-explotación nunca incluye recopilación de evidencia.
Verdadero/Falso: Falso
Explicación: Se documenta impacto y evidencia para reportes y mitigación.
Referencia: [PTES](#)
161. Las vulnerabilidades móviles solo afectan Android.
Verdadero/Falso: Falso
Explicación: iOS y otras plataformas móviles también presentan vulnerabilidades.
Referencia: [OWASP Mobile Top 10](#)
162. MobSF permite análisis estático y dinámico de apps móviles.
Verdadero/Falso: Verdadero
Explicación: Evalúa permisos, configuraciones y comportamiento de apps.
Referencia: [MobSF](#)
163. El malware solo puede analizarse dinámicamente.
Verdadero/Falso: Falso
Explicación: También se puede analizar estáticamente revisando código y binarios.
Referencia: SANS Malware Analysis
164. La ingeniería inversa permite entender comportamiento de software desconocido o malicioso.
Verdadero/Falso: Verdadero
Explicación: Ayuda a identificar vulnerabilidades, riesgos y técnicas maliciosas.
Referencia: ISO/IEC 27035
165. Los tipos de malware incluyen virus, troyanos, ransomware y rootkits.
Verdadero/Falso: Verdadero
Explicación: Cada tipo tiene modo de propagación y objetivos distintos.
Referencia: NIST Malware
166. Los exploits siempre garantizan control completo sobre sistemas vulnerables.
Verdadero/Falso: Falso
Explicación: Depende de la vulnerabilidad y defensas existentes.
Referencia: [OWASP Exploits](#)
167. Python es útil para automatización, exploits y scripting en pentesting.
Verdadero/Falso: Verdadero
Explicación: Su versatilidad permite crear herramientas personalizadas para

pruebas de seguridad.

Referencia: Python Security

168. Escaneo de puertos activo puede generar alertas de IDS/IPS.

Verdadero/Falso: Verdadero

Explicación: Envía paquetes que pueden ser detectados por sistemas de seguridad.

Referencia: [NIST SP 800-115](#)

169. La fase de explotación solo se realiza si no se ha encontrado vulnerabilidad alguna.

Verdadero/Falso: Falso

Explicación: Se realiza sobre vulnerabilidades identificadas para evaluar impacto.

Referencia: [PTES](#)

170. Rootkits pueden ocultar procesos y archivos críticos del sistema.

Verdadero/Falso: Verdadero

Explicación: Esto permite persistencia y control sobre sistemas comprometidos.

Referencia: NIST Malware

171. Las pruebas de caja negra requieren acceso al código fuente.

Verdadero/Falso: Falso

Explicación: Simula un ataque externo sin información interna del sistema.

Referencia: [PTES](#)

172. Las pruebas de caja blanca permiten revisar todo el código fuente para evaluar seguridad.

Verdadero/Falso: Verdadero

Explicación: Permite análisis profundo de todas las rutas de código y posibles vulnerabilidades.

Referencia: [OWASP Testing Guide](#)

173. Las pruebas de caja gris combinan información parcial con técnicas de ataque controladas.

Verdadero/Falso: Verdadero

Explicación: Simula escenarios realistas de ataque con información limitada.

Referencia: [PTES](#)

174. La documentación de hallazgos es irrelevante si el pentest es interno.

Verdadero/Falso: Falso

Explicación: Siempre es necesaria para remediación, auditoría y cumplimiento de normas.

Referencia: [ISO/IEC 27001](#)

175. La explotación ética busca demostrar vulnerabilidades sin causar daños reales.

Verdadero/Falso: Verdadero

Explicación: Es el principio central de las pruebas de penetración seguras.

Referencia: [PTES](#)

176. La fase de post-explotación incluye evaluación de impacto y recopilación de evidencia.

Verdadero/Falso: Verdadero

Explicación: Permite planificar mitigación de riesgos y reportes completos.

Referencia: [PTES](#)

177. Una vulnerabilidad siempre garantiza acceso total al sistema.

Verdadero/Falso: Falso

Explicación: Depende del contexto, controles existentes y tipo de vulnerabilidad.

Referencia: [NIST CVSS](#)

178. Escanear vulnerabilidades sin autorización es ilegal.

Verdadero/Falso: Verdadero

Explicación: Solo se permite dentro de un alcance autorizado y ético.

Referencia: [ISO/IEC 27001](#)

179. La recopilación pasiva nunca incluye motores de búsqueda.

Verdadero/Falso: Falso

Explicación: Google, Shodan y otros motores son fuentes comunes de OSINT pasivo.

Referencia: OSINT Guide

180. Escanear vulnerabilidades repetidamente ayuda a verificar correcciones y remediaciones.

Verdadero/Falso: Verdadero

Explicación: Permite comprobar que las vulnerabilidades identificadas hayan sido mitigadas.

Referencia: [NIST SP 800-115](#)

181. Una prueba de penetración ética no sigue alcance ni autorización definidos.

Verdadero/Falso: Falso

Explicación: Cumplir alcance y autorización es crucial para legalidad y ética.

Referencia: [PTES](#)

182. ARP Spoofing permite interceptar y modificar tráfico en LAN.

Verdadero/Falso: Verdadero

Explicación: Redirige paquetes a un atacante para espionaje o manipulación.

Referencia: OWASP ARP Spoofing

183. El análisis de memoria solo sirve para detectar malware residente.

Verdadero/Falso: Falso

Explicación: También detecta fugas de datos, procesos sospechosos y manipulación de memoria.

Referencia: SANS Memory Forensics

184. Escalar privilegios permite realizar pruebas más completas y evaluar impacto real.
Verdadero/Falso: Verdadero
Explicación: Simula un atacante que obtiene mayor control del sistema.
Referencia: [NIST SP 800-115](#)
185. Las pruebas móviles solo se realizan en dispositivos físicos.
Verdadero/Falso: Falso
Explicación: También se pueden usar emuladores o entornos virtualizados para análisis seguro.
Referencia: [OWASP Mobile Security](#)
186. La explotación ética nunca documenta hallazgos.
Verdadero/Falso: Falso
Explicación: Toda explotación debe documentarse para mitigación y cumplimiento.
Referencia: [PTES](#)
187. Una prueba de caja blanca revisa solo código fuente y no configuración del sistema.
Verdadero/Falso: Falso
Explicación: También revisa configuraciones y dependencias que afecten la seguridad.
Referencia: [OWASP Testing Guide](#)
188. Rootkits permiten mantener persistencia y ocultar actividad maliciosa.
Verdadero/Falso: Verdadero
Explicación: Integración al kernel o procesos críticos dificulta detección y eliminación.
Referencia: NIST Malware
189. El malware solo se propaga mediante archivos ejecutables.
Verdadero/Falso: Falso
Explicación: Puede propagarse mediante documentos, macros, scripts, dispositivos externos y red.
Referencia: NIST Malware
190. Escanear puertos pasivamente permite observar servicios sin enviar tráfico nuevo.
Verdadero/Falso: Verdadero
Explicación: Se analiza tráfico existente para detectar servicios sin alertar al objetivo.
Referencia: [NIST SP 800-115](#)
191. La fase de explotación no es necesaria si no se desea impactar sistemas.
Verdadero/Falso: Falso
Explicación: Es clave para evaluar el impacto de las vulnerabilidades

identificadas.

Referencia: [PTES](#)

192. El análisis estático de código ayuda a identificar vulnerabilidades sin ejecutar la aplicación.

Verdadero/Falso: Verdadero

Explicación: Permite revisar código y binarios para encontrar problemas de seguridad.

Referencia: SANS Malware Analysis

193. Escanear vulnerabilidades sin autorización puede considerarse delito.

Verdadero/Falso: Verdadero

Explicación: Requiere autorización formal para cumplir con la ley y ética profesional.

Referencia: [ISO/IEC 27001](#)

194. Las pruebas de penetración ayudan a cumplir estándares internacionales y certificaciones.

Verdadero/Falso: Verdadero

Explicación: Permiten implementar controles y demostrar cumplimiento con ISO/IEC 27001 u otros marcos.

Referencia: [ISO/IEC 27001](#)

195. Las pruebas de caja negra requieren acceso total al código fuente.

Verdadero/Falso: Falso

Explicación: Se simula un atacante externo sin información interna del sistema.

Referencia: [PTES](#)

196. La fase de post-explotación incluye planificación de mitigación y remediación.

Verdadero/Falso: Verdadero

Explicación: Permite implementar soluciones y reducir riesgos tras la explotación.

Referencia: [PTES](#)

197. Escalar privilegios no tiene utilidad en pentesting interno.

Verdadero/Falso: Falso

Explicación: Es clave para simular ataques internos y evaluar riesgos avanzados.

Referencia: [NIST SP 800-115](#)

198. Python puede usarse para automatización de pruebas de seguridad y exploits.

Verdadero/Falso: Verdadero

Explicación: Es muy usado en scripting, herramientas personalizadas y pentesting.

Referencia: Python Security

199. Escaneo activo de puertos siempre evita alertas de IDS.
Verdadero/Falso: Falso
Explicación: Puede ser detectado ya que envía tráfico que el sistema puede registrar.
Referencia: [NIST SP 800-115](#)
200. Una prueba de penetración ética busca mejorar la seguridad de la organización.
Verdadero/Falso: Verdadero
Explicación: Identifica vulnerabilidades, riesgos y sugiere mitigación, fortaleciendo la postura de seguridad.
Referencia: [ISO/IEC 27001](#)